

Relatório de Auditoria de Segurança

gerenciar-tarefas

Data: 28 de agosto de 2026

Escopo: backend Quarkus 3.2, Java 17, JAX-RS, Panache/Hibernate ORM, OIDC e todos os artefatos locais versionados ou presentes no workspace.

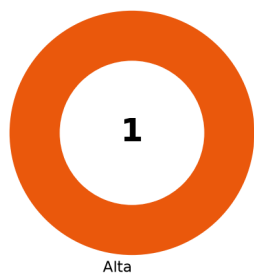
Nota metodológica

A auditoria mapeou cada categoria do prompt para a stack detectada: isolamento por filtro e queries Panache; autorização por política HTTP e RolesAllowed; IDOR em todos os handlers JAX-RS; segredos em configuração, scripts e histórico Git; e XSS em frontend ou respostas HTML. Não foram inventados achados para componentes ausentes.

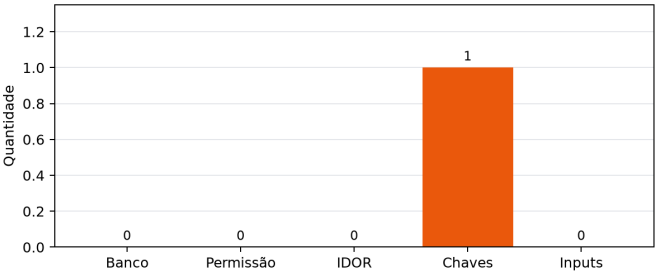
Resumo executivo

O estado atual do backend não apresentou falhas ativas verificadas nas categorias de isolamento, autorização, IDOR ou tratamento de input. Foi confirmado um achado no histórico Git: credenciais antigas em texto claro. A correção do script atual impede novos defaults de senha, mas não remove o risco histórico sem rotação.

Achados por severidade



Achados por categoria



Severidade	Quantidade
Crítica	0
Alta	1
Média	0
Baixa	0

Pontos fortes e pontos fracos

Pontos fortes

- Todas as rotas do recurso /tarefas estão cobertas pela política HTTP authenticated e o teste sem identidade retorna 401. - POST, PUT e DELETE possuem RolesAllowed(ADMIN), com teste de usuário USER retornando 403. - O tenant é derivado do principal autenticado; X-Tenant-Id divergente é rejeitado com 403. - Listagem e busca usam consultas do repositório com tenantId, e a exclusão passa pela mesma busca protegida. - Bean Validation é aplicada ao DTO de entrada e o recurso usa @Valid. - Configuração OIDC e banco não possuem defaults de produção; SecurityConfig falha se valores obrigatórios estiverem ausentes. - Não há frontend, HTML, e-mail ou template no projeto; as respostas do backend são JSON.

Pontos fracos

- O histórico Git ainda contém credenciais antigas e exige rotação imediata. - A política atual de auditoria não consegue provar que credenciais históricas foram revogadas; isso depende de ação operacional fora do código.

Categorias sem aplicação

Não existe frontend no workspace auditado, portanto não se aplica permissão escondida no navegador nem XSS de DOM. Não foram encontrados Docker, CI, Helm ou Terraform no escopo pesquisado.

Achados detalhados

Achados verificados no código real e no histórico Git. A linha de histórico é identificada pelo commit para evitar confusão com o estado atual.

Severidade	Arquivo: linha	Descrição
ALTA	histórico Git 62cb917: apps/backend/start_aplicacao.bat:12,16	O histórico Git contém um segredo OIDC e uma senha DB2 em texto claro (SECRET e DB2_PASSWORD). Mesmo que o arquivo não esteja mais no estado atual, qualquer clone do repositório histórico permite recuperar os valores.

Condições de explorabilidade

O achado histórico é explorável se os valores ainda forem aceitos pelo IdP ou pelo DB2. A análise não presume validade atual: a validade precisa ser confirmada pela rotação e pelos logs dos serviços. O estado atual do script não reintroduz esses valores.

Recomendações priorizadas

P1 - Revogar e rotacionar imediatamente o segredo OIDC e a senha DB2 expostos no commit 62cb917; invalidar sessões ou tokens relacionados se aplicável.

P2 - Adicionar secret scanning no CI e uma política de pre-commit para impedir credenciais em scripts, propriedades e documentação.

P3 - Preservar os testes de 401, 403, isolamento e validação como gate obrigatório em futuras mudanças do backend.

P4 - Se a política de retenção permitir, remover os blobs históricos após rotação, documentando o procedimento e validando todos os clones e mirrors.

ISSUES PARA O GITHUB

Issue acionável pronta para copiar e colar:

```
--- ISSUE 1 ---
Título: [Segurança] Credenciais expostas no histórico Git
Labels sugeridas: security + alta

Descrição do problema:
O histórico Git registra um segredo OIDC e uma senha DB2 em texto claro no script de inicialização.

Por que é explorável:
Qualquer pessoa com acesso ao clone ou aos objetos históricos pode recuperar os valores, mesmo após a
remoção do arquivo da versão atual.

Evidência:
Commit 62cb917, apps/backend/start_aplicacao.bat:12:
set "SECRET=<valor redigido>"
Commit 62cb917, apps/backend/start_aplicacao.bat:16:
set "DB2_PASSWORD=<valor redigido>"

Impacto:
Acesso não autorizado a serviços OIDC ou ao banco DB2, caso as credenciais ainda estejam ativas.

Sugestão de correção:
Revogar e rotacionar imediatamente as credenciais; manter scripts sem valores padrão e, se a política
permitir, remover os segredos do histórico com procedimento documentado.

Critérios de aceite:
- [ ] Credencial OIDC histórica revogada e substituída.
- [ ] Senha DB2 histórica revogada e substituída.
- [ ] Busca automatizada não encontra segredos nos arquivos versionados atuais.
- [ ] O script de inicialização falha quando as variáveis obrigatórias não existem.
--- FIM ISSUE 1 ---
```